

RAPPORT D'AUDIT

Djola TikTak

Audit General du Produit

Analyse fonctionnelle, securitaire et commerciale. Note detaillee par module, valeur marchande, couts et feuille de route strategique.

Aout 2026

Confidentiel

58

SUR 100

Table des matieres

1. Synthese executive	3
1.1 Note globale	3
2. Audit fonctionnel detaille	4
2.1 Authentification	4
2.2 Gestion des Services	4
2.3 Gestion des Clients	4
2.4 Rendez-vous (Dashboard)	5
2.5 Disponibilites	5
2.6 Reservation Publique	5
2.7 Facturation	5
2.8 Paiements	6
2.9 Rappels et Notifications	6
2.10 Administration	6
2.11 PWA Mobile	7
2.12 Themes (7 themes)	7
3. Audit de Securite	7
3.1 Vulnerabilites	7
3.2 Points positifs	8
4. Performance et Architecture	8
4.1 Decisions positives	8
4.2 Problemes	8
5. Qualite du Code	9
5.1 Positifs	9
5.2 Problemes	9
6. Valeur Marchande et Coûts	9
6.1 Valeur marchande estimee	9
6.2 Coûts pre-lancement	10

6.3 Projections de revenus	10
7. Propositions d Amelioration	11
7.1 Phase 1 - Corrections critiques (0-2 semaines)	11
7.2 Phase 2 - Differentiation (2-6 semaines)	11
7.3 Phase 3 - Croissance (1-3 mois)	11
7.4 Phase 4 - Avance (3-6 mois)	12
8. Conclusion et Feuille de Route	12

1. Synthese executive

Djola TikTak est une application SaaS de prise de rendez-vous destinee aux professionnels et petits commerces en Afrique Centrale, principalement au Cameroun. La plateforme permet aux coiffeurs, restaurateurs, consultants et autres artisans de gerer leurs reservations en ligne via une interface mobile-first progressive web app (PWA). Ce rapport presente un audit complet et detaille du produit, fonctionnalite par fonctionnalite, avec une note sur 100 pour chaque module, une estimation de la valeur marchande, une analyse des couts avant les premiers utilisateurs, et des propositions d amelioration pour surpasser la concurrence.

1.1 Note globale

Apres analyse de l ensemble du codebase (42 composants, 28 endpoints API, 17 routes, 18 fichiers lib), la note globale est de **58/100**. Le produit est viable en MVP mais souffre de faiblesses critiques : rappels non fonctionnels, absence de tests, securite a renforcer, et fonctionnalites placeholder.

Module	Note	Verdict
Authentification	72/100	Bon
Gestion des Services	75/100	Bon
Gestion des Clients	68/100	Bon
Rendez-vous Dashboard	78/100	Bon
Disponibilites	82/100	Excellent
Reservation Publique	80/100	Excellent
Facturation	65/100	Bon
Paiements	60/100	Moyen
Rappels	25/100	Critique
Administration	70/100	Bon
PWA Mobile	72/100	Bon
Securite	45/100	Faible
Performance	62/100	Moyen
UI/UX	68/100	Bon
Qualite Code	55/100	Moyen

2. Audit fonctionnel detaille

2.1 Authentification

Le systeme repose sur Supabase Auth, choix solide. Le middleware utilise Promise.race avec timeout 4s contre les 504 Vercel Edge. L inscription cree directement le profil professionnel. Verification email, mot de passe oublie et auto-confirmation admin presents. Cependant, pas de 2FA, pas de OAuth actif (callback existe mais non configure), getSession au lieu de getUser dans le middleware (moins securise en cas de token revoke), et pas de rate limiting sur les tentatives de connexion.

- Forces : Supabase Auth fiable, middleware timeout anti-504, verification email, auto-confirm admin
- Faiblesses : Pas de 2FA, pas de OAuth actif, getSession vs getUser, pas de rate limiting
- Note : **72/100**

2.2 Gestion des Services

Module CRUD complet avec validation Zod, upload d images via Supabase Storage, drag-and-drop (dnd-kit). 612 lignes de code, chaque service a nom, description, prix FCFA, duree (5min-8h), statut, image. Gate de plan integre avec compteur visuel (3/5). Architecture solide mais fichier monolithique a decomposer.

- Forces : CRUD complet, DnD, upload image, Zod, plan-gate, compteur visuel
- Faiblesses : Pas de categories, pas de variantes, fichier monolithique 612 lignes
- Note : **75/100**

2.3 Gestion des Clients

CRUD complet avec recherche ILIKE multi-champs (nom, telephone, email). Deduplication par nom+telephone : si un client existe, ses infos sont mises a jour plutot que creees en doublon. Gate de plan a 200 clients (Starter). Manque historique RDV par client, tags, export CSV, et la suppression est definitive (pas de soft-delete).

- Forces : Recherche multi-champs, deduplication, plan-gate, soft-update
- Faiblesses : Pas d historique RDV, pas de tags, suppression definitive, pas d export

- Note : **68/100**

2.4 Rendez-vous (Dashboard)

Coeur fonctionnel. Verification anti-chevauchement, calcul auto de ends_at, jointures service+client. Filtres par statut (pending/confirmed/cancelled/completed/no_show) et plage de dates. Gate plan : 50/jour (Starter), 100 (Pro), illimite (Business). Vue calendrier. Manque recurrence, waiting list, timezone par RDV, et notes internes.

- Forces : Anti-chevauchement, filtres, plan-gate, vue calendrier
- Faiblesses : Pas de recurrence, pas de waiting list, pas de timezone par RDV
- Note : **78/100**

2.5 Disponibilites

Meilleur module technique. Algorithme propre : filtre regles hebdo, soustrait bloques et RDV, genere slots a intervalle 15min. Exclusion des slots passes. Toggle par jour, blocked_slots, noms FR. Defaut : timezone non gere dans le moteur (dates en UTC), pas de buffer entre RDV.

- Forces : Algorithme propre, slots 15min, blocked_slots, journees toggle, FR
- Faiblesses : Timezone non gere, pas de buffer, pas de multi-professionnel
- Note : **82/100**

2.6 Reservation Publique

Fichier le plus volumineux (1138 lignes). Flow 5 etapes avec Framer Motion : service, date, horaire, coordonnees, confirmation + paiement conditionnel (Orange Money/MTN). URL /[slug]/booking personnalisee. Webhook Chariow securise avec deduplication et gestion sale.completed/sale.refunded.

- Forces : Flow 5 etapes, animations, paiement conditionnel, webhook robuste
- Faiblesses : Fichier monolithique 1138 lignes, pas de confirmation email/SMS
- Note : **80/100**

2.7 Facturation

Architecture multi-couches avec pattern provider. 3 plans (3000/10000/25000 FCFA). Plan-gate server-side avec bypass admin. Metres visuels, badges de statut, historique

paiements. RLS sur tables SQL. Manque : trial auto a l inscription, prorata, facture PDF, page confirmation annulation.

- Forces : Architecture propre, 3 plans calibres, plan-gate, RLS
- Faiblesses : Pas de trial auto, pas de prorata, pas de facture PDF
- Note : **65/100**

2.8 Paiements

3 methodes : Chariow (automatique), Orange Money et MTN MoMo (manuel). Webhook Chariow securise avec verification signature, deduplication, webhook_events table. Flux manuel : affichage coordonnees + confirmation admin. Defaut : pas de verification auto des paiements manuels (APIs Orange/MTN non integrees).

- Forces : Webhook Chariow securise, deduplication, 3 methodes
- Faiblesses : Flux manuel non automatise, pas de reconciliation auto
- Note : **60/100**

2.9 Rappels et Notifications

MODULE LE PLUS FAIBLE. Architecture provider bienensee (4 canaux : email, SMS, WhatsApp, voix) mais 100% non fonctionnel. Provider email = placeholder (console.log). SMS/WhatsApp/Voix commentes. Cron endpoint existe mais marque les rappels comme envoyes sans envoi reel. Pour un produit de prise de RDV, c est un bloqueur majeur qui nuit a la valeur percue.

- Forces : Architecture provider bienensee, cron protege
- Faiblesses : 100% non fonctionnel, zero rappel reel, providers placeholders
- Note : **25/100**

2.10 Administration

Dashboard admin avec metriques, graphiques Recharts, liste utilisateurs avec statut abonnement. Gestion paiements manuels (confirmer/rejeter). Acces via ADMIN_EMAILS. Manque : logs d activite, gestion utilisateurs, export donnees, support client integre.

- Forces : Metriques, graphiques, confirmation paiements
- Faiblesses : Pas de logs, pas de gestion utilisateurs, pas d export
- Note : **70/100**

2.11 PWA Mobile

PWA avec manifest.json (icônes 192/512/1024px, standalone, raccourcis). Service worker hybride : cache-first assets, network-first pages. PWAInstallPrompt, meta Apple presentes. Manque : pre-caching shell pages, page offline fallback, background sync.

- Forces : Manifest complet, SW hybride, install prompt, meta Apple
- Faiblesses : Pas de pre-cache, pas de page offline, pas de background sync
- Note : **72/100**

2.12 Themes (7 themes)

7 themes (default, dark, emerald, ocean, sunset, rose, midnight) en CSS oklch avec next-themes. ThemeToggle popover. Differentiateur notable vs concurrents (light/dark seulement). Implementation propre avec contrastes corrects. Manque couleur personnalisée.

- Forces : 7 themes, oklch moderne, persistance, differentiateur
- Faiblesses : Pas de couleur personnalisée
- Note : **76/100**

3. Audit de Securite

La securite est le point le plus preoccupant. Plusieurs vulnerabilites necessitent une attention immediate avant tout deploiement en production. L analyse couvre authentication, autorisation, protection donnees et infrastructure.

3.1 Vulnerabilites

Vulnerabilite	Localisation	Severite	Description
Injection SQL via recherche	/api/clients	Critique	ILIKE accepte wildcards non echappes dans le parametre search
Pas de rate limiting	Toutes routes API	Critique	Brute force possible sur login et creation de comptes
Cron secret faible	/api/cron/*	Moyen	Comparaison en clair, pas de rotation, pas de HMAC

Vulnerabilite	Localisation	Severite	Description
CORS non restreint	next.config.ts	Moyen	Pas de configuration CORS explicite dans next.config
Upload sans sanitisation	/api/upload	Moyen	MIME verifie mais pas le contenu (exe renomme en jpg possible)

En complement, getSession() dans le middleware ne verifie pas le token aupres du serveur Supabase, ce qui peut accepter un token expire. C est compense par getUser() dans chaque endpoint API protege. Note securite : **45/100**.

3.2 Points positifs

- Politiques RLS actives sur toutes les tables Supabase
- Verification de signature webhook Chariow avec rejet 401
- Validation Zod sur tous les endpoints de creation
- Service-role client isole pour operations administratives
- Plan-gate server-side : limites verifiees cote serveur, pas seulement client

4. Performance et Architecture

La stack Next.js 16 + React 19 + TypeScript + Tailwind CSS 4 + Supabase est un choix excellent offrant bon equilibre performance, developper experience et cout. Cependant, plusieurs decisions impactent la performance.

4.1 Decisions positives

- Next.js 16 App Router + output standalone : optimise pour Vercel serverless
- Supabase backend-as-a-service : elimine serveur dedie, reduit couts
- Middleware Promise.race 4s : solution anti-504 Vercel Edge ingenieuse
- PWA + service worker : ameliore experience sur reseaux mobiles lents (contexte africain)
- Tailwind CSS 4 + Zod : zero CSS mort, validation type-safe

4.2 Problemes

Fichiers monolithiques : booking (1138 lignes), settings (690), services (612). Code legacy present (Prisma, db.ts) mais non utilise. reactStrictMode desactive, ignoreBuildErrors a true, ESLint permissif. Zero tests (pas de Jest/Vitest). Landing page en client-side alors que c

est du statique (SEO impacte). Note performance : **62/100**.

5. Qualite du Code

La qualite est correcte pour un demarrage mais presente des incoherences pour la mise a l echelle. TypeScript est utilise partout avec types dans types/database.ts, mais des types any subsistent dans les jointures.

5.1 Positifs

- Types definis pour toutes les entites (Profile, Service, Client, Appointment)
- Pattern provider paiements (chariow-provider.ts), plan-gate centralise
- Schemas Zod complets avec messages en francais
- SQL propre : migration RLS, index, fonctions

5.2 Problemes

- Code legacy non nettoye : Prisma, db.ts, subscription/chariow.ts obsoletes
- 3 fichiers > 600 lignes (monolithiques)
- Types any dans jointures Supabase non strictement definis
- Zero tests unitaires ou d integration
- ESLint trop permissif, reactStrictMode desactive
- Note qualite code : **55/100**

6. Valeur Marchande et Couts

6.1 Valeur marchande estimee

L estimation repose sur trois methodes complementaires. Le cout de redeveloppement est base sur 1600-2400h a 5000 FCFA/h pour un dev senior en Afrique Centrale, soit 8-12 millions FCFA. L approche actifs evalue le code, design et base de donnees a 4-6 millions. La moyenne ponderee donne 5-7.5 millions FCFA (environ 8 000 - 12 500 USD).

Methode	Valeur
Cout de redeveloppement	8 000 000 - 12 000 000 FCFA

Methode	Valeur
Approche par actifs	4 000 000 - 6 000 000 FCFA
Multiple revenus (1.5x ARR)	3 000 000 - 5 000 000 FCFA
Valeur estimee (moyenne)	5 000 000 - 7 500 000 FCFA

6.2 Coûts pre-lancement

L architecture choisie permet un lancement a cout quasi nul. Vercel Hobby et Supabase Free couvrent les besoins initiaux. Le seul cout est le nom de domaine (1500-5000 FCFA/an). Les couts augmenteront significativement seulement apres 200-500 utilisateurs actifs, moment ou les revenus depasseront largement les frais.

Poste	Cout	Type	Notes
Vercel (Hobby)	0 FCFA/mois	Gratuit	100GB bande passante
Supabase (Free)	0 FCFA/mois	Gratuit	500MB BDD, 50K auth/mois
Nom de domaine	1 500 - 5 000 FCFA/an	Annuel	.cm, .com, .gq
SMS/WhatsApp (futur)	50 000 - 150 000 FCFA	Variable	Necessaire pour les rappels
Total pre-lancement	0 - 5 000 FCFA/mois		Cout quasi nul

6.3 Projections de revenus

Scenario	Utilisateurs an 1	Conversion	Abonnes	Revenu/mois	Revenu/an
Pessimiste	200	5%	10	45 000 FCFA/mois	540 000 FCFA/an
Realiste	500	10%	50	350 000 FCFA/mois	4 200 000 FCFA/an
Optimiste	1 000	15%	150	1 350 000 FCFA/mois	16 200 000 FCFA/an

Le scenario realiste projette 4.2M FCFA/an avec 50 abonnes. Le point mort est atteint des les premiers abonnes. Les 3 plans (3000/10000/25000 FCFA) sont bien calibres pour le marche camerounais.

7. Propositions d Amelioration

Pour surpasser les concurrents (Calendly, Doodle, BookMeBus), Djola TikTak doit se differencier sur 3 axes : hyper-localisation africaine, innovation experience client, et robustesse operationnelle.

7.1 Phase 1 - Corrections critiques (0-2 semaines)

- **Activer les rappels SMS/WhatsApp** : Integrer Twilio Africa ou Africa Talking. Reduction no-show 60-80%. Priorite maximale. Impact direct sur la valeur percue du produit.
- **Corriger vulnerabilites securite** : Echapper ILIKE, ajouter rate limiting (Vercel Edge), renforcer verification webhook. Protection donnees utilisateurs.
- **Activer trial automatique** : 7 jours essai gratuit Pro a l inscription. Standard SaaS manquant. Augmentation taux conversion 200-300%.
- **Email confirmation reservation** : Utiliser Resend ou Supabase Edge Functions. Professionnalisme et confiance client immediats.

7.2 Phase 2 - Differentiation (2-6 semaines)

- **Intégration WhatsApp Business API** : Reservation via chatbot WhatsApp. WhatsApp est l app la plus utilisee en Afrique. Aucun concurrent international ne le fait. Impact : acquisition massive.
- **Paiement mobile automatise** : Integrer les APIs Orange Money et MTN MoMo pour verification auto des transactions. Eliminer la dependance admin.
- **Systeme d avis et notes** : Permettre aux clients de laisser des avis apres rendez-vous. Affichage sur la page publique. Social proof essentiel pour les artisans.
- **Multi-professionnel** : Permettre a une boutique d avoir plusieurs professionnels avec calendriers independants. Essentiel pour les salons et cliniques.

7.3 Phase 3 - Croissance (1-3 mois)

- **Programme de parrainage** : Un professionnel parraine un autre, les deux gagnent 1 mois gratuit. Croissance virale dans les communautes de metiers.
- **Tableau de bord analytics avance** : Chiffre d affaires par service, taux de no-show, heures les plus demandees, clients recurrents. Aide a la prise de decision business.
- **Intégration Google Calendar** : Synchronisation bidirectionnelle pour les professionnels qui utilisent deja Google Calendar.

- **Application native** : Wrapper React Native ou Capacitor autour de la PWA pour publication sur Google Play Store. La PWA seule limite la decouverte.
- **SEO local** : Pages publiques optimisees pour le referencement local (Google Business Profile, meta donnees structurees). Un coiffeur a Douala doit etre trouvable sur Google.

7.4 Phase 4 - Avance (3-6 mois)

- **IA pour recommandations** : Suggérer les meilleurs creneaux selon l historique, predire les no-show, optimiser automatiquement les disponibilités.
- **Marketplace** : Annuaire des professionnels utilisant Djola TikTok, searchable par localisation et metier. Revenu supplementaire via commissions.
- **API ouverte** : Permettre aux developpeurs tiers de creer des integrations (ex : caisse enregistreuse, CRM). Creer un ecosysteme.
- **Multi-pays** : Adapter les prix et les methodes de paiement pour le Senegal, Cote d Ivoire, Congo, Gabon. Chaque pays a ses specificites de paiement mobile.

8. Conclusion et Feuille de Route

Djola TikTok est un produit avec un potentiel reel sur le marche africain de la prise de rendez-vous. L architecture technique est moderne et bien choisie, le cout de lancement est quasi nul, et le modele economique est viable. Cependant, la note de 58/100 reflète un produit qui necessite un travail significatif avant d etre pret pour une acquisition massive d utilisateurs. Les priorites absolues sont : activer les rappels, corriger les vulnerabilites, et activer le trial automatique. Ces 3 corrections seules feraient monter la note a environ 72/100 et transformeraient le produit d un MVP prometteur en un SaaS credible.

La feuille de route recommandee est : Phase 1 (semaines 1-2) corrections critiques, Phase 2 (semaines 3-8) differentiation concurrentielle, Phase 3 (mois 2-4) croissance et acquisition, Phase 4 (mois 4-8) avance et scale. Avec un investissement concentre de 2-3 mois de developpement, Djola TikTok peut atteindre une note de 80/100 et se positionner comme la reference de la prise de rendez-vous en Afrique Centrale.

RAPPORT D'AUDIT

Djola TikTak

Audit General du Produit

Analyse fonctionnelle, securitaire et commerciale. Note detaillee par module, valeur marchande, couts et feuille de route strategique.

Aout 2026

Confidentiel

58

SUR 100

Table des matieres

1. Synthese executive	3
1.1 Note globale	3
2. Audit fonctionnel detaille	4
2.1 Authentification	4
2.2 Gestion des Services	4
2.3 Gestion des Clients	4
2.4 Rendez-vous (Dashboard)	5
2.5 Disponibilites	5
2.6 Reservation Publique	5
2.7 Facturation	5
2.8 Paiements	6
2.9 Rappels et Notifications	6
2.10 Administration	6
2.11 PWA Mobile	7
2.12 Themes (7 themes)	7
3. Audit de Securite	7
3.1 Vulnerabilites	7
3.2 Points positifs	8
4. Performance et Architecture	8
4.1 Decisions positives	8
4.2 Problemes	8
5. Qualite du Code	9
5.1 Positifs	9
5.2 Problemes	9
6. Valeur Marchande et Couts	9
6.1 Valeur marchande estimee	9
6.2 Couts pre-lancement	10

6.3 Projections de revenus	10
7. Propositions d Amelioration	11
7.1 Phase 1 - Corrections critiques (0-2 semaines)	11
7.2 Phase 2 - Differentiation (2-6 semaines)	11
7.3 Phase 3 - Croissance (1-3 mois)	11
7.4 Phase 4 - Avance (3-6 mois)	12
8. Conclusion et Feuille de Route	12

1. Synthese executive

Djola TikTak est une application SaaS de prise de rendez-vous destinee aux professionnels et petits commerces en Afrique Centrale, principalement au Cameroun. La plateforme permet aux coiffeurs, restaurateurs, consultants et autres artisans de gerer leurs reservations en ligne via une interface mobile-first progressive web app (PWA). Ce rapport presente un audit complet et detaille du produit, fonctionnalite par fonctionnalite, avec une note sur 100 pour chaque module, une estimation de la valeur marchande, une analyse des couts avant les premiers utilisateurs, et des propositions d amelioration pour surpasser la concurrence.

1.1 Note globale

Apres analyse de l ensemble du codebase (42 composants, 28 endpoints API, 17 routes, 18 fichiers lib), la note globale est de **58/100**. Le produit est viable en MVP mais souffre de faiblesses critiques : rappels non fonctionnels, absence de tests, securite a renforcer, et fonctionnalites placeholder.

Module	Note	Verdict
Authentification	72/100	Bon
Gestion des Services	75/100	Bon
Gestion des Clients	68/100	Bon
Rendez-vous Dashboard	78/100	Bon
Disponibilites	82/100	Excellent
Reservation Publique	80/100	Excellent
Facturation	65/100	Bon
Paiements	60/100	Moyen
Rappels	25/100	Critique
Administration	70/100	Bon
PWA Mobile	72/100	Bon
Securite	45/100	Faible
Performance	62/100	Moyen
UI/UX	68/100	Bon
Qualite Code	55/100	Moyen

2. Audit fonctionnel detaille

2.1 Authentification

Le systeme repose sur Supabase Auth, choix solide. Le middleware utilise Promise.race avec timeout 4s contre les 504 Vercel Edge. L inscription cree directement le profil professionnel. Verification email, mot de passe oublie et auto-confirmation admin presents. Cependant, pas de 2FA, pas de OAuth actif (callback existe mais non configure), getSession au lieu de getUser dans le middleware (moins securise en cas de token revoke), et pas de rate limiting sur les tentatives de connexion.

- Forces : Supabase Auth fiable, middleware timeout anti-504, verification email, auto-confirm admin
- Faiblesses : Pas de 2FA, pas de OAuth actif, getSession vs getUser, pas de rate limiting
- Note : **72/100**

2.2 Gestion des Services

Module CRUD complet avec validation Zod, upload d images via Supabase Storage, drag-and-drop (dnd-kit). 612 lignes de code, chaque service a nom, description, prix FCFA, duree (5min-8h), statut, image. Gate de plan integre avec compteur visuel (3/5). Architecture solide mais fichier monolithique a decomposer.

- Forces : CRUD complet, DnD, upload image, Zod, plan-gate, compteur visuel
- Faiblesses : Pas de categories, pas de variantes, fichier monolithique 612 lignes
- Note : **75/100**

2.3 Gestion des Clients

CRUD complet avec recherche ILIKE multi-champs (nom, telephone, email). Deduplication par nom+telephone : si un client existe, ses infos sont mises a jour plutot que creees en doublon. Gate de plan a 200 clients (Starter). Manque historique RDV par client, tags, export CSV, et la suppression est definitive (pas de soft-delete).

- Forces : Recherche multi-champs, deduplication, plan-gate, soft-update
- Faiblesses : Pas d historique RDV, pas de tags, suppression definitive, pas d export

- Note : **68/100**

2.4 Rendez-vous (Dashboard)

Coeur fonctionnel. Verification anti-chevauchement, calcul auto de ends_at, jointures service+client. Filtres par statut (pending/confirmed/cancelled/completed/no_show) et plage de dates. Gate plan : 50/jour (Starter), 100 (Pro), illimite (Business). Vue calendrier. Manque recurrence, waiting list, timezone par RDV, et notes internes.

- Forces : Anti-chevauchement, filtres, plan-gate, vue calendrier
- Faiblesses : Pas de recurrence, pas de waiting list, pas de timezone par RDV
- Note : **78/100**

2.5 Disponibilites

Meilleur module technique. Algorithme propre : filtre regles hebdo, soustrait bloques et RDV, genere slots a intervalle 15min. Exclusion des slots passes. Toggle par jour, blocked_slots, noms FR. Defaut : timezone non gere dans le moteur (dates en UTC), pas de buffer entre RDV.

- Forces : Algorithme propre, slots 15min, blocked_slots, journees toggle, FR
- Faiblesses : Timezone non gere, pas de buffer, pas de multi-professionnel
- Note : **82/100**

2.6 Reservation Publique

Fichier le plus volumineux (1138 lignes). Flow 5 etapes avec Framer Motion : service, date, horaire, coordonnees, confirmation + paiement conditionnel (Orange Money/MTN). URL /[slug]/booking personnalisee. Webhook Chariow securise avec deduplication et gestion sale.completed/sale.refunded.

- Forces : Flow 5 etapes, animations, paiement conditionnel, webhook robuste
- Faiblesses : Fichier monolithique 1138 lignes, pas de confirmation email/SMS
- Note : **80/100**

2.7 Facturation

Architecture multi-couches avec pattern provider. 3 plans (3000/10000/25000 FCFA). Plan-gate server-side avec bypass admin. Metres visuels, badges de statut, historique

paiements. RLS sur tables SQL. Manque : trial auto a l inscription, prorata, facture PDF, page confirmation annulation.

- Forces : Architecture propre, 3 plans calibres, plan-gate, RLS
- Faiblesses : Pas de trial auto, pas de prorata, pas de facture PDF
- Note : **65/100**

2.8 Paiements

3 methodes : Chariow (automatique), Orange Money et MTN MoMo (manuel). Webhook Chariow securise avec verification signature, deduplication, webhook_events table. Flux manuel : affichage coordonnees + confirmation admin. Defaut : pas de verification auto des paiements manuels (APIs Orange/MTN non integrees).

- Forces : Webhook Chariow securise, deduplication, 3 methodes
- Faiblesses : Flux manuel non automatise, pas de reconciliation auto
- Note : **60/100**

2.9 Rappels et Notifications

MODULE LE PLUS FAIBLE. Architecture provider bienensee (4 canaux : email, SMS, WhatsApp, voix) mais 100% non fonctionnel. Provider email = placeholder (console.log). SMS/WhatsApp/Voix commentes. Cron endpoint existe mais marque les rappels comme envoyes sans envoi reel. Pour un produit de prise de RDV, c est un bloqueur majeur qui nuit a la valeur percue.

- Forces : Architecture provider bienensee, cron protege
- Faiblesses : 100% non fonctionnel, zero rappel reel, providers placeholders
- Note : **25/100**

2.10 Administration

Dashboard admin avec metriques, graphiques Recharts, liste utilisateurs avec statut abonnement. Gestion paiements manuels (confirmer/rejeter). Acces via ADMIN_EMAILS. Manque : logs d activite, gestion utilisateurs, export donnees, support client integre.

- Forces : Metriques, graphiques, confirmation paiements
- Faiblesses : Pas de logs, pas de gestion utilisateurs, pas d export
- Note : **70/100**

2.11 PWA Mobile

PWA avec manifest.json (icônes 192/512/1024px, standalone, raccourcis). Service worker hybride : cache-first assets, network-first pages. PWAInstallPrompt, meta Apple presentes. Manque : pre-caching shell pages, page offline fallback, background sync.

- Forces : Manifest complet, SW hybride, install prompt, meta Apple
- Faiblesses : Pas de pre-cache, pas de page offline, pas de background sync
- Note : **72/100**

2.12 Themes (7 themes)

7 themes (default, dark, emerald, ocean, sunset, rose, midnight) en CSS oklch avec next-themes. ThemeToggle popover. Differentiateur notable vs concurrents (light/dark seulement). Implementation propre avec contrastes corrects. Manque couleur personnalisée.

- Forces : 7 themes, oklch moderne, persistance, differentiateur
- Faiblesses : Pas de couleur personnalisée
- Note : **76/100**

3. Audit de Securite

La securite est le point le plus preoccupant. Plusieurs vulnerabilites necessitent une attention immediate avant tout deploiement en production. L analyse couvre authentication, autorisation, protection donnees et infrastructure.

3.1 Vulnerabilites

Vulnerabilite	Localisation	Severite	Description
Injection SQL via recherche	/api/clients	Critique	ILIKE accepte wildcards non echappes dans le parametre search
Pas de rate limiting	Toutes routes API	Critique	Brute force possible sur login et creation de comptes
Cron secret faible	/api/cron/*	Moyen	Comparaison en clair, pas de rotation, pas de HMAC

Vulnerabilite	Localisation	Severite	Description
CORS non restreint	next.config.ts	Moyen	Pas de configuration CORS explicite dans next.config
Upload sans sanitisation	/api/upload	Moyen	MIME verifie mais pas le contenu (exe renomme en jpg possible)

En complement, getSession() dans le middleware ne verifie pas le token aupres du serveur Supabase, ce qui peut accepter un token expire. C est compense par getUser() dans chaque endpoint API protege. Note securite : **45/100**.

3.2 Points positifs

- Politiques RLS actives sur toutes les tables Supabase
- Verification de signature webhook Chariow avec rejet 401
- Validation Zod sur tous les endpoints de creation
- Service-role client isole pour operations administratives
- Plan-gate server-side : limites verifiees cote serveur, pas seulement client

4. Performance et Architecture

La stack Next.js 16 + React 19 + TypeScript + Tailwind CSS 4 + Supabase est un choix excellent offrant bon equilibre performance, developper experience et cout. Cependant, plusieurs decisions impactent la performance.

4.1 Decisions positives

- Next.js 16 App Router + output standalone : optimise pour Vercel serverless
- Supabase backend-as-a-service : elimine serveur dedie, reduit couts
- Middleware Promise.race 4s : solution anti-504 Vercel Edge ingenieuse
- PWA + service worker : ameliore experience sur reseaux mobiles lents (contexte africain)
- Tailwind CSS 4 + Zod : zero CSS mort, validation type-safe

4.2 Problemes

Fichiers monolithiques : booking (1138 lignes), settings (690), services (612). Code legacy present (Prisma, db.ts) mais non utilise. reactStrictMode desactive, ignoreBuildErrors a true, ESLint permissif. Zero tests (pas de Jest/Vitest). Landing page en client-side alors que c

est du statique (SEO impacte). Note performance : **62/100**.

5. Qualite du Code

La qualite est correcte pour un demarrage mais presente des incoherences pour la mise a l echelle. TypeScript est utilise partout avec types dans types/database.ts, mais des types any subsistent dans les jointures.

5.1 Positifs

- Types definis pour toutes les entites (Profile, Service, Client, Appointment)
- Pattern provider paiements (chariow-provider.ts), plan-gate centralise
- Schemas Zod complets avec messages en francais
- SQL propre : migration RLS, index, fonctions

5.2 Problemes

- Code legacy non nettoye : Prisma, db.ts, subscription/chariow.ts obsoletes
- 3 fichiers > 600 lignes (monolithiques)
- Types any dans jointures Supabase non strictement definis
- Zero tests unitaires ou d integration
- ESLint trop permissif, reactStrictMode desactive
- Note qualite code : **55/100**

6. Valeur Marchande et Couts

6.1 Valeur marchande estimee

L estimation repose sur trois methodes complementaires. Le cout de redeveloppement est base sur 1600-2400h a 5000 FCFA/h pour un dev senior en Afrique Centrale, soit 8-12 millions FCFA. L approche actifs evalue le code, design et base de donnees a 4-6 millions. La moyenne ponderee donne 5-7.5 millions FCFA (environ 8 000 - 12 500 USD).

Methode	Valeur
Cout de redeveloppement	8 000 000 - 12 000 000 FCFA

Methode	Valeur
Approche par actifs	4 000 000 - 6 000 000 FCFA
Multiple revenus (1.5x ARR)	3 000 000 - 5 000 000 FCFA
Valeur estimee (moyenne)	5 000 000 - 7 500 000 FCFA

6.2 Coûts pre-lancement

L architecture choisie permet un lancement a cout quasi nul. Vercel Hobby et Supabase Free couvrent les besoins initiaux. Le seul cout est le nom de domaine (1500-5000 FCFA/an). Les couts augmenteront significativement seulement apres 200-500 utilisateurs actifs, moment ou les revenus depasseront largement les frais.

Poste	Cout	Type	Notes
Vercel (Hobby)	0 FCFA/mois	Gratuit	100GB bande passante
Supabase (Free)	0 FCFA/mois	Gratuit	500MB BDD, 50K auth/mois
Nom de domaine	1 500 - 5 000 FCFA/an	Annuel	.cm, .com, .gq
SMS/WhatsApp (futur)	50 000 - 150 000 FCFA	Variable	Necessaire pour les rappels
Total pre-lancement	0 - 5 000 FCFA/mois		Cout quasi nul

6.3 Projections de revenus

Scenario	Utilisateurs an 1	Conversion	Abonnes	Revenu/mois	Revenu/an
Pessimiste	200	5%	10	45 000 FCFA/mois	540 000 FCFA/an
Realiste	500	10%	50	350 000 FCFA/mois	4 200 000 FCFA/an
Optimiste	1 000	15%	150	1 350 000 FCFA/mois	16 200 000 FCFA/an

Le scenario realiste projette 4.2M FCFA/an avec 50 abonnes. Le point mort est atteint des les premiers abonnes. Les 3 plans (3000/10000/25000 FCFA) sont bien calibres pour le marche camerounais.

7. Propositions d Amelioration

Pour surpasser les concurrents (Calendly, Doodle, BookMeBus), Djola TikTok doit se differencier sur 3 axes : hyper-localisation africaine, innovation experience client, et robustesse operationnelle.

7.1 Phase 1 - Corrections critiques (0-2 semaines)

- **Activer les rappels SMS/WhatsApp** : Integrer Twilio Africa ou Africa Talking. Reduction no-show 60-80%. Priorite maximale. Impact direct sur la valeur percue du produit.
- **Corriger vulnerabilites securite** : Echapper ILIKE, ajouter rate limiting (Vercel Edge), renforcer verification webhook. Protection donnees utilisateurs.
- **Activer trial automatique** : 7 jours essai gratuit Pro a l inscription. Standard SaaS manquant. Augmentation taux conversion 200-300%.
- **Email confirmation reservation** : Utiliser Resend ou Supabase Edge Functions. Professionnalisme et confiance client immediats.

7.2 Phase 2 - Differentiation (2-6 semaines)

- **Intégration WhatsApp Business API** : Reservation via chatbot WhatsApp. WhatsApp est l app la plus utilisee en Afrique. Aucun concurrent international ne le fait. Impact : acquisition massive.
- **Paiement mobile automatise** : Integrer les APIs Orange Money et MTN MoMo pour verification auto des transactions. Eliminer la dependance admin.
- **Systeme d avis et notes** : Permettre aux clients de laisser des avis apres rendez-vous. Affichage sur la page publique. Social proof essentiel pour les artisans.
- **Multi-professionnel** : Permettre a une boutique d avoir plusieurs professionnels avec calendriers independants. Essentiel pour les salons et cliniques.

7.3 Phase 3 - Croissance (1-3 mois)

- **Programme de parrainage** : Un professionnel parraine un autre, les deux gagnent 1 mois gratuit. Croissance virale dans les communautes de metiers.
- **Tableau de bord analytics avance** : Chiffre d affaires par service, taux de no-show, heures les plus demandees, clients recurrents. Aide a la prise de decision business.
- **Intégration Google Calendar** : Synchronisation bidirectionnelle pour les professionnels qui utilisent deja Google Calendar.

- **Application native** : Wrapper React Native ou Capacitor autour de la PWA pour publication sur Google Play Store. La PWA seule limite la decouverte.
- **SEO local** : Pages publiques optimisees pour le referencement local (Google Business Profile, meta donnees structurees). Un coiffeur a Douala doit etre trouvable sur Google.

7.4 Phase 4 - Avance (3-6 mois)

- **IA pour recommandations** : Suggérer les meilleurs creneaux selon l historique, predire les no-show, optimiser automatiquement les disponibilités.
- **Marketplace** : Annuaire des professionnels utilisant Djola TikTok, searchable par localisation et metier. Revenu supplementaire via commissions.
- **API ouverte** : Permettre aux developpeurs tiers de creer des integrations (ex : caisse enregistreuse, CRM). Creer un ecosysteme.
- **Multi-pays** : Adapter les prix et les methodes de paiement pour le Senegal, Cote d Ivoire, Congo, Gabon. Chaque pays a ses specificites de paiement mobile.

8. Conclusion et Feuille de Route

Djola TikTok est un produit avec un potentiel reel sur le marche africain de la prise de rendez-vous. L architecture technique est moderne et bien choisie, le cout de lancement est quasi nul, et le modele economique est viable. Cependant, la note de 58/100 reflète un produit qui necessite un travail significatif avant d etre pret pour une acquisition massive d utilisateurs. Les priorites absolues sont : activer les rappels, corriger les vulnerabilites, et activer le trial automatique. Ces 3 corrections seules feraient monter la note a environ 72/100 et transformeraient le produit d un MVP prometteur en un SaaS credible.

La feuille de route recommandee est : Phase 1 (semaines 1-2) corrections critiques, Phase 2 (semaines 3-8) differentiation concurrentielle, Phase 3 (mois 2-4) croissance et acquisition, Phase 4 (mois 4-8) avance et scale. Avec un investissement concentre de 2-3 mois de developpement, Djola TikTok peut atteindre une note de 80/100 et se positionner comme la reference de la prise de rendez-vous en Afrique Centrale.